

Incident Response Plan

Bright Smile Family Dentistry — Mock Organization

DOCUMENT DATE	PREPARED BY	VERSION
May 2026	Melissa Gaither, CompTIA Security+	1.0

CLASSIFICATION	FRAMEWORK
Confidential	NIST SP 800-61 & HIPAA Security Rule

TABLE OF CONTENTS

1. Purpose and Scope
2. Incident Response Team
3. Incident Classification
4. Phase 1 — Preparation
5. Phase 2 — Identification
6. Phase 3 — Containment
7. Phase 4 — Eradication
8. Phase 5 — Recovery
9. Phase 6 — Lessons Learned
10. Ransomware Scenario Walkthrough
11. HIPAA Notification Requirements
12. Document Review and Maintenance

1 Purpose and Scope

This Incident Response Plan (IRP) establishes procedures for detecting, responding to, and recovering from cybersecurity incidents affecting electronic Protected Health Information (ePHI) at **Bright Smile Family Dentistry**. It is designed to minimize damage, reduce recovery time, and ensure compliance with the HIPAA Security Rule (45 CFR § 164.308(a)(6)).

This plan applies to all staff, systems, and business associates that create, receive, maintain, or transmit ePHI, including clinical workstations, practice management software, digital imaging systems, email platforms, and backup systems.

Regulatory Basis

The HIPAA Security Rule requires covered entities to implement policies and procedures to address security incidents, including identifying and responding to suspected or known incidents, mitigating harmful effects, and documenting incidents and outcomes (§164.308(a)(6)(ii)).

2 Incident Response Team

The following roles make up the Incident Response Team (IRT). All members must be familiar with this plan and participate in annual training and tabletop exercises.

INCIDENT RESPONSE LEAD

Office Manager

Overall coordination and decision-making
Phone: [Office Manager Phone]

SECURITY OFFICER

Designated Staff Member

HIPAA compliance and documentation
Phone: [Security Officer Phone]

IT SUPPORT (MSP)

Managed Service Provider

Technical response and remediation
Emergency Line: [MSP Emergency #]

PRACTICE OWNER

Lead Dentist / Owner

Final authority on major decisions
Phone: [Owner Phone]

LEGAL COUNSEL

Practice Attorney

HHS / OCR CONTACT

HHS Office for Civil Rights

Legal guidance on breach notification
Phone: [Attorney Phone]

Breach reporting portal
ocrportal.hhs.gov

CHAIN OF COMMAND

☐ **STEP 1 – ANY STAFF MEMBER**

Detects or suspects an incident → immediately reports to Office Manager. Do not attempt to investigate or fix it independently.

☐ **STEP 2 – OFFICE MANAGER**

Receives report → contacts IT MSP emergency line and notifies Security Officer. Begins incident log.

☐ **STEP 3 – IT MSP**

Assesses technical scope → advises on containment steps → begins remediation.

☐ **STEP 4 – SECURITY OFFICER**

Determines if ePHI was involved → initiates HIPAA breach assessment → coordinates notification if required.

☐ **STEP 5 – PRACTICE OWNER / LEGAL**

Notified for major incidents → approves patient notification decisions → authorizes media or HHS reporting if required.

3 Incident Classification

Not every security event is a full-blown incident. The following classification helps the team respond proportionally.

Level	Description	Examples	Response
Low	Minimal impact, no ePHI involved	Spam email, failed login attempt	Log and monitor
Medium	Potential ePHI exposure, limited scope	Lost unencrypted USB drive, phishing click with no data confirmed stolen	Activate IRT, investigate within 24 hrs
High	Confirmed ePHI exposure or system compromise	Confirmed phishing breach, unauthorized access by former employee	Full IRT activation, begin HIPAA assessment
Critical	Major system compromise or mass ePHI breach	Ransomware attack, large-scale data theft	Full IRT + Legal + possible law enforcement

4 The Six Phases of Incident Response

1 Preparation

Everything that must be in place before an incident occurs

Preparation is the most important phase. A practice that is well-prepared responds faster, recovers faster, and faces less regulatory exposure when an incident occurs.

- | | |
|--|-------------------------|
| ☐ This Incident Response Plan is documented, approved, and accessible to all IRT members | <i>Security Officer</i> |
| ☐ All IRT members have been trained on this plan and know their roles | <i>Office Manager</i> |
| ☐ Annual tabletop exercise conducted to simulate an incident scenario | <i>Security Officer</i> |
| ☐ All staff have completed HIPAA security awareness training including phishing recognition | <i>Office Manager</i> |
| ☐ Clean, tested data backups exist and are stored securely offsite or in the cloud | <i>IT MSP</i> |
| ☐ All staff have individual login credentials (no shared accounts) | <i>IT MSP</i> |
| ☐ All laptops and workstations have full-disk encryption enabled | <i>IT MSP</i> |
| ☐ Antivirus and endpoint protection software is installed and up to date on all devices | <i>IT MSP</i> |
| ☐ All software patches are applied on a regular schedule | <i>IT MSP</i> |
| ☐ Business Associate Agreements are in place with all vendors who handle ePHI | <i>Office Manager</i> |
| ☐ IRT contact list is printed and posted in the office (not only stored digitally) | <i>Office Manager</i> |
| ☐ Incident log template is ready and accessible | <i>Security Officer</i> |

2

Identification

Recognizing that an incident has occurred or is occurring

Identification begins the moment something suspicious is noticed. Speed matters — the faster an incident is identified and reported, the less damage it causes.

COMMON WARNING SIGNS IN A DENTAL OFFICE

- ☐ Computers are unresponsive, unusually slow, or programs will not open
- ☐ A pop-up appears demanding payment to unlock files (ransomware)
- ☐ Staff receive emails asking them to click a link or enter their password
- ☐ A patient calls to report a suspicious email that appears to be from the office
- ☐ A staff member's login is showing activity while they are not at their workstation
- ☐ The insurance clearinghouse reports unusual activity on the practice's account
- ☐ Files are missing, renamed, or cannot be opened
- ☐ Antivirus software generates an alert or shuts down unexpectedly

IDENTIFICATION CHECKLIST

- ☐ Staff member reports suspicious activity to Office Manager *All Staff*
immediately — do not attempt to investigate independently
- ☐ Office Manager opens incident log and records: date, time, who *Office Manager*
reported it, and what was observed
- ☐ Office Manager contacts IT MSP to assess whether a real *Office Manager*
incident has occurred
- ☐ IT MSP confirms incident and classifies severity (Low / Medium / High / *IT MSP*
Critical)
- ☐ Security Officer notified if ePHI may be involved *Office Manager*
- ☐ Practice Owner notified for High or Critical incidents *Office Manager*

3

Containment

Stop the incident from spreading — act fast



Critical Rule: Do Not Touch the Affected System

The first instinct is to click around and try to fix it. This almost always makes things worse. Leave the affected computer exactly as it is and follow the steps below.

IMMEDIATE CONTAINMENT (FIRST 15 MINUTES)

- ☐ Do not click anything on the affected computer — leave it exactly as found *All Staff*
- ☐ Do not turn off the affected computer unless directed by IT MSP (turning it off may destroy evidence) *All Staff*
- ☐ Disconnect the affected computer from the network — unplug the ethernet cable and/or disable WiFi *Office Manager / IT MSP*
- ☐ Shut down or disconnect other workstations from the network to prevent spread *Office Manager / IT MSP*
- ☐ Do not log into any systems using potentially compromised credentials *All Staff*
- ☐ Contact IT MSP emergency line immediately *Office Manager*

SHORT-TERM CONTAINMENT (FIRST FEW HOURS)

- ☐ IT MSP assesses full scope of compromise across all systems *IT MSP*
- ☐ Isolate any additional affected systems identified during assessment *IT MSP*
- ☐ Change passwords for all staff accounts from an unaffected device *IT MSP + Office Manager*
- ☐ Determine whether ePHI was accessed or exfiltrated *IT MSP + Security Officer*
- ☐ Preserve all logs and evidence — do not delete anything *IT MSP*
- ☐ Consider whether to continue operating on paper records temporarily *Office Manager + Practice Owner*
- ☐ Notify legal counsel if ePHI breach is confirmed or suspected *Practice Owner*

4 Eradication

Find the cause and remove it completely

Eradication ensures the threat is fully removed before any systems are brought back online. Rushing this phase risks reinfection.

- ☐ IT MSP performs full forensic scan of all affected systems to identify malware, backdoors, or unauthorized access points *IT MSP*
- ☐ Identify the root cause — how did the attacker get in? (phishing link, unpatched software, weak password, etc.) *IT MSP*
- ☐ Remove all malware, ransomware, or malicious files from affected systems *IT MSP*
- ☐ Reimage (wipe and rebuild) any systems that cannot be fully cleaned *IT MSP*
- ☐ Apply all outstanding software patches and security updates *IT MSP*
- ☐ Remove or disable any unauthorized user accounts created during the incident *IT MSP*
- ☐ Verify all systems are clean before proceeding to Recovery *IT MSP*
- ☐ Document all findings and actions taken during eradication *Security Officer*

5 Recovery

Restore systems and return to normal operations safely

Recovery is not just about turning computers back on — it requires careful validation to ensure everything is working correctly and securely before patients are seen.

- ☐ Restore patient data and records from the most recent clean backup *IT MSP*
- ☐ Reinstall all practice software — Dentrix, Eaglesoft, imaging software, and billing platforms *IT MSP*

- | | |
|---|--------------------------------------|
| ☐ Calibrate digital X-ray sensors and imaging equipment after system restoration | <i>Lead Dentist / Clinical Staff</i> |
| <hr/> | |
| ☐ Test all systems thoroughly before returning to patient care | <i>IT MSP + Office Manager</i> |
| <hr/> | |
| ☐ Verify patient data integrity — confirm records are complete and accurate | <i>Office Manager</i> |
| <hr/> | |
| ☐ Reset all staff passwords and enforce new strong password requirements | <i>IT MSP</i> |
| <hr/> | |
| ☐ Re-enable multi-factor authentication on all accounts if applicable | <i>IT MSP</i> |
| <hr/> | |
| ☐ Monitor all systems closely for 30 days post-recovery for signs of reinfection | <i>IT MSP</i> |
| <hr/> | |
| ☐ Communicate with staff about the return to normal operations and any changes to procedures | <i>Office Manager</i> |
| <hr/> | |
| ☐ Document the date and time systems were restored and declared clean | <i>Security Officer</i> |

6

Lessons Learned

Document, train, and update — prevent it from happening again

The Lessons Learned phase should occur within 2 weeks of the incident being resolved. Skipping this phase means the practice is likely to experience the same incident again.

- | | |
|---|-------------------------|
| ☐ Hold a formal after-action meeting with all IRT members within 14 days of resolution | <i>Security Officer</i> |
| <hr/> | |
| ☐ Review the full incident log and timeline as a team | <i>All IRT</i> |
| <hr/> | |
| ☐ Answer: What happened? How did it start? How was it detected? | <i>All IRT</i> |
| <hr/> | |
| ☐ Answer: What did we do well? What could have been faster or better? | <i>All IRT</i> |

- | | |
|--|----------------------------------|
| ☐ Identify the root cause and confirm it has been fully addressed | <i>IT MSP + Security Officer</i> |
| <hr/> | |
| ☐ Update this Incident Response Plan based on lessons learned | <i>Security Officer</i> |
| <hr/> | |
| ☐ Conduct targeted staff training based on how the incident occurred (e.g., phishing awareness if a phishing email was clicked) | <i>Office Manager</i> |
| <hr/> | |
| ☐ Implement any new technical or administrative controls identified during the review | <i>IT MSP + Office Manager</i> |
| <hr/> | |
| ☐ Produce a written after-action report and file with incident documentation | <i>Security Officer</i> |

10 Ransomware Scenario Walkthrough

The following is a step-by-step walkthrough of how this IRP applies to a ransomware attack — the most critical cybersecurity threat facing dental and healthcare practices today.

Scenario: Monday Morning Ransomware Attack

A front desk staff member arrives and turns on their workstation. A full-screen pop-up appears stating all files are encrypted and demanding \$50,000 in Bitcoin to restore access. The Dentrix software will not open.

☐ IMMEDIATE — 0 TO 15 MINUTES

Do not touch or click anything on the affected computer. Staff member immediately notifies Office Manager. Office Manager calls IT MSP emergency line. Other staff are told not to log into any computers.

☐ 15 TO 60 MINUTES — CONTAINMENT

IT MSP advises disconnecting all workstations from the network. Office Manager disconnects ethernet cables and disables WiFi on all machines. Practice moves to paper records for the day. Security Officer notified and begins incident log.

☐ HOUR 1 TO 4 — ASSESSMENT

IT MSP arrives onsite or connects remotely to an unaffected device. Determines scope — which systems are encrypted, whether data was exfiltrated, and how the ransomware

entered (likely a phishing email or unpatched vulnerability). Practice Owner and Legal Counsel notified.

 DAY 1 TO 3 – ERADICATION

IT MSP wipes and reimages all affected systems. Removes ransomware and any backdoors. Applies all security patches. Changes all staff passwords. Verifies network is clean before restoration begins.

 DAY 3 TO 5 – RECOVERY

Patient data restored from clean backups. Software reinstalled and tested. X-ray sensors and imaging systems calibrated. Practice returns to normal operations. Systems monitored closely.

 WITHIN 60 DAYS – HIPAA NOTIFICATION

If ePHI was confirmed accessed or exfiltrated, affected patients notified in writing. HHS OCR notified via ocrportal.hhs.gov. If 500+ patients affected in Ohio, local media notified. All notification documentation filed.

 WITHIN 14 DAYS OF RESOLUTION – LESSONS LEARNED

After-action meeting held. IRP updated. Staff retrained on phishing awareness. New controls implemented to prevent recurrence. Written after-action report filed.

11 HIPAA Notification Requirements

When a breach of ePHI is confirmed, HIPAA's Breach Notification Rule (45 CFR §§ 164.400–414) requires the following notifications:

Who to Notify	Deadline	Method	Trigger
Affected Patients	Within 60 days of discovery	Written notice by first-class mail	Any confirmed ePHI breach
HHS Office for Civil Rights	Within 60 days (500+) or annually (under 500)	ocrportal.hhs.gov	Any confirmed ePHI breach
Prominent Local Media	Within 60 days of discovery	Press release or media notification	500+ patients in a single state affected
Business Associates	Without unreasonable delay	Direct notification per BAA terms	If BA caused or discovered the breach

Important: Ransom Payment Does NOT Eliminate Notification Requirement

Paying a ransom and receiving a decryption key does not mean ePHI was not accessed. HIPAA requires notification unless the practice can demonstrate through a forensic investigation that the data was not actually accessed or exfiltrated. When in doubt, notify.

12 Document Review and Maintenance

Activity	Frequency	Owner
Full IRP review and update	Annual	Security Officer
Tabletop exercise / simulation	Annual	Security Officer + All IRT
Staff security awareness training	Annual	Office Manager
IRT contact list verification	Semi-Annual	Office Manager
Backup restoration test	Quarterly	IT MSP
Review after any real incident	Within 14 days of incident	Security Officer

Portfolio Note: This is a mock Incident Response Plan created as a cybersecurity career portfolio project. Bright Smile Family Dentistry is a fictional organization. All procedures are based on real HIPAA Security Rule requirements and NIST SP 800-61 (Computer Security Incident Handling Guide) methodology.

REFERENCES

- NIST SP 800-61 Rev 2 — Computer Security Incident Handling Guide. <https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final>
- HHS Office for Civil Rights — Breach Notification Rule. <https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html>
- HHS OCR — Ransomware and HIPAA Guidance. <https://www.hhs.gov/hipaa/for-professionals/security/guidance/ransomware/index.html>
- CompTIA Security+ Study Guide, Exam SY0-701

Prepared by: **Melissa Gaither** | CompTIA Security+ | GitHub: CyberMomma-3

This document is part of a cybersecurity career transition portfolio.